**BAB II**

# DOKUMENTASI SPESIFIKASI API (RESTFUL ENDPOINTS)

*Katalog Endpoint Publik & Administratif, Format JSON Envelope, JWT & Rate Limiter*

| | |
|---|---|
| **Penyusun / Penulis:** | Saya (Fullstack Developer & System Architect) |
| **Entitas Perusahaan:** | PT. Global Philsonic Technologies (GPT) — Unit Bisnis PT. Intersis Sejahtera Abadi (ISA) |
| **Kawasan Operasional:** | Batam Free Trade Zone (FTZ), Kepulauan Riau, Indonesia |
| **Tanggal & Status:** | Oktober 2026 • Dokumen Final Teknis (Monokrom Standar) |

## 2.1 Arsitektur & Standar Respons RESTful API

Saya merancang antarmuka Application Programming Interface (API) berbasis arsitektur RESTful yang memanfaatkan protokol HTTP dan format payload JSON. Seluruh endpoint mengembalikan struktur respons yang seragam untuk mempermudah integrasi dan penanganan kesalahan pada sisi klien:

```
// Format Respons Sukses:
{
  "success": true,
  "message": "Data berhasil diambil",
  "data": { ... },
  "meta": { "total": 12, "page": 1, "limit": 10 } // Opsional jika paginasi
}

// Format Respons Gagal / Error:
{
  "success": false,
  "message": "Deskripsi kesalahan yang terjadi",
  "errors": [ { "field": "email", "message": "Format email tidak valid" } ] // Opsional
}
```

## 2.2 Mekanisme Keamanan, Autentikasi, & Rate Limiting

Untuk menjaga keandalan dan keamanan data perusahaan, saya menerapkan standar keamanan berlapis:

- **JSON Web Token (JWT):** Endpoint administratif dilindungi dengan verifikasi token JWT melalui header HTTP `Authorization: Bearer [token]`. Token memiliki masa berlaku terbatas dan diverifikasi oleh middleware `verifyToken`.
- **Role-Based Access Control (RBAC):** Sistem membatasi hak akses pengguna ke dalam tiga tingkatan melalui middleware `restrictTo(...)`:
  - `administrator`: Hak akses penuh ke seluruh modul, pengaturan sistem, dan manajemen user.
  - `hrd`: Mengelola lowongan kerja, data pelamar, konten perusahaan, dan akun staf.
  - `staff`: Mengelola operasional entri konten website publik (read, create, update terbatas).

- **Rate Limiting:** Saya memasang limitasi permintaan menggunakan `express-rate-limit` guna menangkal serangan brute-force dan Denial of Service (DoS):
  - `apiLimiter`: Maksimum 200 permintaan per jendela 15 menit untuk endpoint publik.
  - `authLimiter`: Maksimum 5 percobaan login gagal per 15 menit per alamat IP.
  - `rfqSubmissionLimiter`: Maksimum 10 pengiriman RFQ per 1 jam per alamat IP.

## 2.3 Katalog Endpoint Publik (Read-Only & Interaksi Klien)

| Method | Endpoint URL | Deskripsi Fungsi & Parameter |
|---|---|---|
| GET | /api/company | Mengambil data profil perusahaan, visi, misi, deskripsi bilingual, dan tautan gambar banner. |
| GET | /api/core-values | Mengambil daftar 4 pilar nilai inti perusahaan (SMT Precision, IATF 16949, Smart Jigs, FTZ). |
| GET | /api/contact | Mengambil informasi kontak resmi recruitment dan perusahaan (email, alamat, telepon, media sosial). |
| GET | /api/trade-destinations | Mengambil data hub ekspor logistik Batam FTZ (Singapore, USA, Japan, Europe, China). |
| GET | /api/site-settings | Mengambil konfigurasi visual situs (logo URL, favicon, nomor telepon darurat, status operasional). |
| POST | /api/telemetry/visit | Mencatat log kunjungan pengunjung secara anonim untuk statistik performa antarmuka. |
| POST | /api/rfq | Menerima pengiriman formulir RFQ dari calon klien industri. Memeriksa validitas email dan nomor telepon. |
| GET | /api/job-categories | Mengambil daftar kategori divisi pekerjaan yang memiliki status aktif. |
| GET | /api/jobs | Mengambil daftar lowongan kerja berstatus 'published' dengan query params: category, type, search, page. |
| GET | /api/jobs/:id | Mengambil detail lengkap lowongan kerja (tanggung jawab, persyaratan, batas waktu lamaran). |
| GET | /api/benefits | Mengambil daftar fasilitas dan kompensasi kerja yang ditawarkan kepada karyawan. |
| GET | /api/programs | Mengambil program pembinaan karir (Internship/Magang, Management Trainee, On-the-Job Training). |
| GET | /api/programs/:slugOrId | Mengambil detail spesifik program magang atau pelatihan berdasarkan slug URL atau ID. |
| GET | /api/faqs | Mengambil daftar pertanyaan yang sering diajukan (FAQ) seputar proses rekrutmen. |
| GET | /api/gallery | Mengambil galeri dokumentasi foto kegiatan fasilitas kerja, perakitan, dan lingkungan pabrik. |
| GET | /api/products | Mengambil katalog 12 produk elektronik manufaktur GPT dengan filter parameter category. |

## 2.4 Katalog Endpoint Administratif (Protected Admin Routes)

| Method | Endpoint URL | Role Diizinkan | Keterangan Aksi |
|---|---|---|---|
| POST | /api/admin/auth/login | Publik (Rate Limited) | Autentikasi admin; mengembalikan token JWT dan profil. |
| GET | /api/admin/auth/me | Semua Role Terdaftar | Verifikasi validitas token sesi dan identitas user. |
| PUT | /api/admin/auth/change-password | Semua Role Terdaftar | Mengganti password akun user aktif setelah validasi lama. |
| POST | /api/admin/translate | administrator, hrd, staff | Mesin bantu terjemahan otomatis konten ID ke EN. |
| GET / POST | /api/admin/users | administrator, hrd | Melihat daftar user dan mendaftarkan akun internal baru. |
| PUT / DELETE | /api/admin/users/:id | administrator, hrd | Memperbarui role/status user atau menghapus user. |
| PUT | /api/admin/company | administrator, hrd, staff | Memperbarui profil perusahaan dan unggah banner utama. |
| PUT | /api/admin/contact | administrator, hrd, staff | Memperbarui kontak, tautan sosial media, dan WhatsApp. |
| POST | /api/admin/upload | administrator, hrd, staff | Unggah berkas gambar multipart dengan pembersihan berkas lama. |
| GET / POST | /api/admin/jobs | administrator, hrd, staff | Mengambil semua status lowongan dan membuat lowongan baru. |
| PUT / DELETE | /api/admin/jobs/:id | administrator, hrd, staff | Memperbarui kualifikasi atau menghapus lowongan. |
| CRUD | /api/admin/products | administrator, hrd, staff | Manajemen spesifikasi produk otomasi dan headunit. |
| CRUD | /api/admin/benefits | administrator, hrd, staff | Manajemen data fasilitas benefit kerja. |
| CRUD | /api/admin/programs | administrator, hrd, staff | Manajemen informasi program magang dan pelatihan. |
| CRUD | /api/admin/faqs | administrator, hrd, staff | Manajemen daftar pertanyaan tanya-jawab rekrutmen. |
| GET | /api/admin/activity-logs | administrator, hrd | Audit trail rekaman aktivitas modifikasi data oleh user. |